PRÁCTICA 04 - RESPUESTA A UN INCIDENTE DE SEGURIDAD

Seguridad y Alta Disponibilidad

Pedro Hosannah - 2º ASIR

1. Contexto del incidente

En esta práctica se plantea un incidente de seguridad en la empresa SecureTech S.L. La empresa tiene 25 equipos de usuario, 2 servidores Linux, 1 servidor Windows, un router/firewall, dos puntos de acceso Wi-Fi y servicios como web, archivos, DNS y SSH.

El problema empieza cuando un trabajador abre un archivo adjunto que le llega por correo. Después de abrirlo, el equipo empieza a comportarse de forma rara: aparecen archivos que antes no estaban, algunos cambian de extensión y el tráfico de red aumenta bastante. También se ven conexiones hacia direcciones externas y otros usuarios empiezan a tener problemas para acceder a ciertos archivos.

Por lo que se describe, yo pensaría primero en algún tipo de malware y, por los cambios en los archivos, podría ser ransomware. Aun así, no lo daría por seguro hasta revisar los registros y comprobar qué ha pasado realmente.

2. Identificación y clasificación del ataque

Yo clasificaría el incidente como un ataque de malware. Además, como todo empieza por un archivo que el usuario abre desde el correo, también hay una parte de ingeniería social, ya que el atacante consigue que la propia víctima ejecute el archivo.

Respecto a los principios básicos de seguridad, lo vería de esta forma:

- Disponibilidad: está afectada porque algunos usuarios ya no pueden acceder bien a determinados archivos.
- Integridad: también está afectada, ya que hay archivos que han cambiado de extensión o han podido ser modificados.
- Confidencialidad: no se puede confirmar todavía, pero las conexiones externas hacen necesario comprobar si ha salido información de la empresa.
- Autenticidad: podría estar afectada si el correo se hacía pasar por una persona o empresa conocida.

Para comprobarlo miraría el correo original, los procesos que se han ejecutado, los archivos modificados, los inicios de sesión y los logs del firewall y de los servidores. También revisaría las conexiones de red del equipo afectado.

También lo clasificaría por el efecto que tiene sobre la información:

- Interrupción: aparece cuando un recurso deja de estar disponible. En este caso encaja con los usuarios que no pueden acceder a determinados archivos.
- Modificación: se produce cuando la información cambia sin autorización. Los archivos que han cambiado de extensión o contenido son la evidencia más clara.

- Interceptación: sería el acceso a información por alguien que no debería verla. No está confirmado, pero las conexiones externas obligan a comprobar si se han enviado datos fuera de la empresa.
- Suplantación: consiste en hacerse pasar por otro usuario o servicio. Podría haber ocurrido si el correo malicioso imitaba a una persona o empresa conocida.

Por la técnica utilizada, la entrada más probable sería un correo de phishing o ingeniería social con un archivo adjunto malicioso. Después habría que comprobar si el malware consiguió persistencia, más privilegios o movimiento lateral. Esa parte no la daría por confirmada sin revisar las evidencias.

3. Reconstrucción de la anatomía del ataque

La secuencia siguiente es una reconstrucción posible a partir de los síntomas del enunciado. No asumiría que todas las fases ocurrieron; las comprobaría con registros, archivos y conexiones de red.

Fase	Qué podría haber ocurrido	Evidencias que buscaría	Sistemas afectados	Qué podría haberlo frenado
1. Reconocimiento	El atacante podría haber recopilado información pública sobre la empresa, sus usuarios y los servicios expuestos.	Esta fase puede dejar pocos rastros. Revisaría los registros del firewall y la actividad dirigida a los servicios publicados.	Router/firewall y servicios expuestos.	Reducir la información y los servicios publicados y vigilar la exposición externa.
2. Acceso inicial	El empleado recibe el correo y abre el archivo adjunto malicioso.	Correo y adjunto recibido, junto con los registros del servidor de correo y del firewall perimetral.	Equipo del empleado y servicio de correo.	Antispam y filtrado de contenidos, además de formación para no abrir adjuntos o enlaces sospechosos.
3. Ejecución	El archivo ejecuta el malware en el equipo.	Procesos nuevos o anómalos y alertas del antivirus o del EDR/XDR.	Equipo inicialmente infectado.	Antivirus/ antimalware, EDR/XDR y monitorización de la ejecución de procesos.

Fase	Qué podría haber ocurrido	Evidencias que buscaría	Sistemas afectados	Qué podría haberlo frenado
4. Persistencia	El malware podría intentar seguir activo después de reiniciar mediante una tarea programada, un servicio nuevo o una entrada de arranque.	Tareas programadas, servicios nuevos o cambios en los elementos de inicio.	Equipo infectado.	EDR/XDR, revisión de la ejecución de procesos y mínimo privilegio.
5. Escalada de privilegios	Podría intentar conseguir credenciales con más privilegios para ampliar lo que puede hacer dentro del sistema.	Registros de autenticación y uso anómalo de cuentas con privilegios.	Equipo infectado y cuentas de usuario.	Parches al día, mínimo privilegio y MFA en las cuentas sensibles.
6. Movimiento lateral	Podría intentar pasar a otros equipos usando credenciales o herramientas legítimas de administración.	Registros de autenticación y acceso remoto desde orígenes o equipos no habituales.	Equipos de usuarios y servidores accesibles desde la red.	Segmentación interna y restricción de las cuentas administrativas por origen.
7. Mando y control	El equipo comprometido podría establecer un canal saliente con el atacante.	Registros del firewall y del DNS, además de conexiones salientes poco habituales.	Equipos infectados, DNS y router/firewall.	Control del tráfico de salida e IDS/IPS.

Fase	Qué podría haber ocurrido	Evidencias que buscaría	Sistemas afectados	Qué podría haberlo frenado
8. Acción sobre el objetivo	El malware podría cifrar o modificar archivos y afectar a recursos compartidos.	Cambios de extensión, archivos inaccesibles y aumento anómalo de actividad en disco o red.	Equipo infectado, carpetas compartidas y servidor de archivos.	Antivirus/EDR, mínimo privilegio, segmentación y copias de seguridad para la recuperación.
9. Exfiltración, si procede	Antes o durante el cifrado podría intentar enviar información al exterior. El enunciado no confirma que haya ocurrido.	Aumento del tráfico saliente y conexiones a destinos externos desconocidos.	Equipos o servidores a los que pudiera acceder la cuenta comprometida.	Monitorización del tráfico, control de salida e IDS/IPS.

4. Respuesta ante el incidente

4.1. Aislamiento

Lo primero sería evitar que el problema se extienda. Desconectaría de la red los equipos que tengan síntomas, tanto del cable de red como del Wi-Fi, para cortar la propagación.

También limitaría el acceso de esos equipos a los servidores. Si durante el análisis encuentro una IP o un dominio claramente malicioso, lo bloquearía desde el firewall.

4.2. Análisis

Cuando el incidente esté contenido, empezaría a revisar qué ha ocurrido. Miraría los procesos en ejecución, los archivos creados o modificados recientemente, las conexiones de red, los inicios de sesión y las tareas programadas.

También revisaría los registros del firewall y de los servidores, porque pueden ayudar a saber desde cuándo empezó el problema y si el malware ha intentado llegar a otros equipos.

El archivo adjunto también habría que analizarlo. Empezaría por un análisis estático, sin ejecutarlo. Si fuera necesario probarlo, lo haría dentro de una máquina virtual aislada para no poner en riesgo la red real.

4.3. Eliminación

Después intentaría eliminar el malware con una herramienta antivirus, antimalware o EDR. No me quedaría solo con borrar el archivo inicial, porque también habría que comprobar servicios, tareas programadas u otros cambios que haya podido dejar el malware.

Si no pudiera estar seguro de que el equipo está limpio, me parecería más seguro reinstalarlo desde una imagen de confianza.

4.4. Restauración

Para recuperar la información usaría una copia de seguridad anterior al incidente, comprobando antes que esa copia también esté limpia. No volvería a conectar los equipos a la red hasta comprobar que están actualizados y funcionan con normalidad.

4.5. Cerrar la vulnerabilidad

Una vez recuperados los equipos, todavía quedaría corregir la causa del problema. Aplicaría las actualizaciones pendientes, cambiaría las contraseñas de las cuentas que puedan haberse visto afectadas y cerraría servicios o puertos que no sean necesarios.

También mejoraría el filtrado del correo y recordaría a los usuarios que no deben abrir adjuntos o enlaces dudosos, aunque el mensaje parezca venir de una persona conocida.

5. Prevención y monitorización

5.1. Antivirus y antimalware

Usaría antivirus/antimalware junto con una solución EDR/XDR. El antivirus ayudaría a detectar y bloquear malware, mientras que el EDR/XDR permitiría detectar y responder a comportamientos sospechosos en los equipos.

Lo instalaría en los equipos de usuario y en los servidores compatibles. Mantendría la protección y sus actualizaciones al día y revisaría que los equipos sigan protegidos y que las alertas se estén registrando.

5.2. Actualizaciones y gestión de parches

Mantendría actualizados los sistemas operativos, las aplicaciones y el firmware. Probaría los parches antes de aplicarlos en producción, los desplegaría de forma planificada y automatizaría el proceso cuando fuera posible.

Si un equipo utiliza software obsoleto o sin soporte, intentaría actualizarlo o sustituirlo, porque deja de recibir parches y queda expuesto a vulnerabilidades conocidas.

5.3. Control de acceso, monitorización y Wi-Fi

Usaría contraseñas seguras y MFA cuando sea posible. Además, cada usuario debería tener solo los permisos que necesita para trabajar, para que una cuenta comprometida no tenga acceso a más cosas de las necesarias.

Para detectar problemas antes, revisaría de forma periódica los logs del firewall, de los servidores, del DNS y de los accesos. También se podrían utilizar sistemas IDS para detectar actividad extraña y un IPS si se quiere bloquear parte de esa actividad de forma automática.

En la red Wi-Fi usaría WPA3 si los equipos lo permiten o una configuración segura de WPA2. La red de invitados debería estar separada de la red interna de la empresa.

Con estas medidas intentaría cubrir las distintas capas que pide el proyecto: prevenir antes del incidente, detectar actividad rara, responder rápido, recuperar los sistemas y corregir la causa para que no se repita.

6. Hardening de los sistemas

La idea del hardening sería dejar los servidores con solo lo que realmente necesitan. Cuantos menos servicios, usuarios y puertos innecesarios haya, menos puntos tendrá un atacante para intentar entrar.

Entre las medidas que aplicaría estarían:

- Desactivar servicios que no se utilicen: reduce la superficie de ataque y evita mantener procesos expuestos sin necesidad.
- Cerrar puertos que no estén justificados: evita accesos a servicios que la empresa no necesita publicar.
- Eliminar cuentas antiguas o que ya no hagan falta: reduce la posibilidad de que una cuenta olvidada se use para entrar.
- Revisar los permisos de usuarios y carpetas: limita el daño si una cuenta queda comprometida.
- Usar las cuentas de administrador solo cuando sea necesario: evita trabajar todo el tiempo con permisos elevados.
- Limitar el acceso por SSH a los equipos o usuarios autorizados: reduce intentos de acceso remoto desde orígenes que no deberían administrarlos.
- Mantener el sistema actualizado y revisar la configuración del firewall: corrige vulnerabilidades conocidas y controla qué tráfico puede entrar o salir.
- Usar contraseñas robustas y MFA cuando sea posible: dificulta el acceso aunque una contraseña termine expuesta.
- Revisar el arranque y el acceso físico a los servidores: evita que alguien pueda saltarse controles del sistema arrancando desde otro medio.

7. Seguridad del arranque en Linux

En los servidores Linux también protegería el arranque, porque una persona con acceso físico al equipo podría intentar modificarlo.

Pondría una contraseña en la BIOS o UEFI y dejaría el disco interno como primera opción de arranque. Si no hace falta arrancar desde USB o desde red, esas opciones las dejaría desactivadas.

Mantendría Secure Boot activado si el equipo es compatible para evitar que durante el arranque se carguen componentes no firmados o modificados. Si el servidor dispone de TPM, lo usaría como apoyo para proteger claves y comprobar cambios en la cadena de arranque.

También protegería GRUB con contraseña. Si cualquiera puede editar sus entradas, podría cambiar parámetros de arranque e intentar iniciar el sistema de una forma menos segura o saltarse parte de la configuración habitual.

Aun así, esto no sustituye al cifrado del disco. Si alguien saca un disco sin cifrar y lo conecta a otro ordenador, podría intentar leer su contenido.

8. Particionado y cifrado

En un servidor Linux separaría /var, /var/log, /home y /tmp. No los separaría solo por orden, sino para poder aplicar límites y opciones distintas según el tipo de datos que guarda cada zona.

- /var: guarda muchos datos que cambian con el funcionamiento de servicios. Si crece demasiado, una partición separada evita que llene directamente el sistema raíz.
- /var/log: mantiene los registros separados del resto de /var. Así un crecimiento anormal de logs no ocupa todo el espacio disponible para otros datos.
- /home: separa las carpetas personales del resto del sistema y permite aplicar opciones de montaje específicas como nodev y nosuid.
- /tmp: contiene archivos temporales y es una zona en la que interesa aplicar más restricciones, porque distintos procesos y usuarios pueden escribir en ella.

Según la partición, usaría opciones de montaje como estas:

- nodev: impide que los archivos de esa partición se interpreten como dispositivos.
- nosuid: hace que no tengan efecto los bits SUID y SGID, reduciendo posibilidades de ejecutar programas con privilegios distintos a los del usuario.
- noexec: impide ejecutar directamente binarios desde esa partición y es útil en zonas como /tmp cuando no se necesita ejecutar programas desde allí.

Para los datos sensibles usaría LUKS para cifrar el volumen. El contenido permanecería protegido cuando el servidor esté apagado o si se extrae el disco, porque haría falta la clave o el método de desbloqueo configurado para montar el volumen.

Eso sí, cuando el servidor está encendido y el volumen está montado, el cifrado por sí solo no es suficiente. Siguen siendo importantes los permisos, el hardening y la monitorización.

9. Cierre del incidente

Yo daría el incidente por cerrado cuando el malware esté eliminado, los archivos se hayan recuperado, las contraseñas comprometidas se hayan cambiado y la causa inicial del ataque esté corregida.

Antes de volver a la normalidad comprobaría que los equipos estén actualizados y que no aparezcan nuevas conexiones o comportamientos extraños.

En los días siguientes seguiría revisando los registros con más frecuencia por si quedara algo sin detectar.

En resumen, primero intentaría frenar la propagación y averiguar qué ha ocurrido. Después limpiaría o reinstalaría los equipos afectados, recuperaría los datos desde una copia segura y

corregiría la causa que permitió el incidente. A partir de ahí mantendría las medidas de prevención y monitorización como parte del trabajo normal de administración.